Security, privacy & Canadian compliance

The compliance-by-design gates IronWrap has to clear before launch — consent, safeguards, recording notice, CASL, retention — written as build gates, not legal theory.

IRONWRAP EXTERIORS • REV. JUNE 2026

Position

The system is built compliant-by-design for Canadian operations. This pack doesn't replace legal counsel — it defines the go-live gates we have to satisfy before production launch.

OFFICIAL SOURCES CHECKED · 27 JUNE 2026

- OPC Canada — PIPEDA fair information principles.
- Alberta PIPA.
- CRTC — CASL guidance.
- National DNCL.
- OPC — call-recording guidance.
- Alberta / OIPC — breach guidance.

Compliance map

AREA	REQUIREMENT	BUILD GATE
Consent & notice	Customers must know why information is collected and how it's used	Website form, call script, SMS/email wording approved
Website tracking & attribution	Source URL / UTM / call tracking and review requests must preserve consent and opt-out	Form consent language, tracking, and review stop-conditions tested
Limited collection	Collect only the information the job needs	Field allowlist per integration
Limited use	Use personal information only for stated purposes	No broad sync into unrelated tools
Safeguards	Protect personal information with reasonable security	Named users, MFA, least privilege, secret storage

AREA	REQUIREMENT	BUILD GATE
Access & correction	Customer information must be retrievable / correctable	Job / customer data map documented
Service providers	IronWrap stays accountable for its vendors	Vendor register and terms review
Cross-border processing	Customers may need notice if providers outside Canada handle data	Privacy notice includes outside-Canada language if applicable
Breach response	Record and report qualifying breaches	Breach playbook approved
CASL	Commercial electronic messages need consent, identification, unsubscribe	Consent fields and unsubscribe handling tested
DNCL	Telemarketing-style outbound calls must respect DNCL / internal DNC	Outbound call policy approved
Call recording	Recording / transcription needs notice and purpose	Start-of-call notice approved

Data classification

CLASS	EXAMPLES	HANDLING
Public	Website copy, public service list	Normal
Customer personal information	Name, phone, email, address, job details, photos, website-uploaded files, uploaded visualizer media	Approved systems only — store website uploads only in approved job folders
Sensitive operational	Insurance claim details, complaints, warranty issues	Limited access
Finance sensitive	Card / bank / PAD / financing docs	QuickBooks / payment processor only — never AI logs
Secrets	API keys, passwords, webhooks	Password manager only

AI & privacy rules

AI TOOLS MUST NOT RECEIVE

- Payment card details.
- Bank / PAD details.
- Financing documents.
- Unnecessary customer documents.
- Home photos or visualizer media, unless the use and vendor are explicitly approved.
- Legal disputes.
- Warranty decisions.
- Insurance determinations beyond approved intake questions.

AI TOOLS MAY RECEIVE

- Customer contact details needed for the call, if the vendor is approved.
- Address / scope needed to book or qualify.
- Approved FAQ and service-area info.
- De-identified summaries for testing.

Call recording & AI notice

The approved call opening must cover:

- The caller is speaking with an AI assistant, if AI is in use.
- The call may be recorded / transcribed, if enabled.
- Purpose — scheduling, lead intake, service follow-up, quality, and recordkeeping.
- The caller can ask for a human.

No production AI call launches until the wording is approved.

CASL requirements for SMS / email

BEFORE ANY MARKETING, NURTURE, OR REVIEW SEQUENCE

- Store consent status.
- Store consent source / date if available.
- Identify IronWrap.
- Include unsubscribe / stop handling.
- Stop messages after opt-out.
- Stop review pressure on complaint or dispute.

Transactional messages like appointment confirmations still need sensible handling — they must not turn into hidden marketing.

DNCL / outbound call rules

BEFORE OUTBOUND, TELEMARKETING-STYLE CAMPAIGNS

- Check National DNCL obligations.
- Maintain an internal do-not-call list.
- Honor human requests not to be called.
- Keep call purpose and source documented.

Retention rules

Define retention before launch for:

- Lead records.
- Call recordings.
- Transcripts.
- SMS / email history.
- Photos.
- Renoworks / home-visualizer uploads, if active.
- Measurement reports.
- Proposals / contracts.
- Accounting records.
- Warranty / service records.

DEFAULT

- Keep what's needed for job delivery, accounting, warranty, legal, and customer service.
- Delete or archive what's no longer needed.
- Limit transcript / recording access.

Payment compliance notes

- Card data stays inside approved processors such as Moneris or another approved provider.
- Bank / PAD / direct-deposit details never enter AI logs, broad CRM notes, or Make logs unless explicitly required and approved.
- FinanceIT applications and financing documents are sensitive — they stay in the approved financing / accounting flow.
- AI and staff scripts never imply financing approval, insurance approval, or guaranteed premium discounts.
- Customer-facing payment and financing wording is approved before proposal launch.

Final security hardening phase

After build, config, and test — before launch:

1. Rotate every credential pasted in chat or used during testing.
2. Revoke old sessions and stale API keys.
3. Replace shared logins with named users.
4. Enable MFA where available.
5. Create service / API accounts where supported.
6. Store secrets in a password manager.
7. Set least-privilege roles.
8. Lock down GHL, JobNimbus, Make, QuickBooks, storage, AI voice, OCR, proposal tools.
9. Confirm field allowlists per integration.
10. Confirm no finance-sensitive data leaks into AI / transcripts / logs.
11. Approve the vendor register and privacy notice.
12. Confirm call-recording, CASL, DNCL, retention, and breach rules.
13. Confirm kill switches and owners.

Go-live compliance gate

NO PRODUCTION LAUNCH UNTIL

- Privacy notice reviewed.
- Website form consent language approved.
- AI / call-recording notice approved.
- CASL consent / unsubscribe tested.
- DNCL / internal DNC policy approved for outbound.
- Vendor register complete.
- Cross-border / service-provider notice decided.
- Retention schedule approved.
- Breach-response steps documented.
- Access hardening complete.